

1. (16 points) Classify each of the following as an example of a mandatory, discretionary, or originator controlled policy, or a combination thereof. Justify your answers.

- a. The file access control mechanisms of the UNIX operating system
 - Answer: Discretionary access control because in the UNIX operating system, each file has an owner that decides who can perform actions like read, write, and execute using permissions they have set. This means that the owner controls access, so it must be discretionary access control.
- b. A system in which no memorandum can be distributed without the creator's consent
 - Answer: Originator-controlled access control because the creator/originator maintains control over who can access the information, even after it is created, which is the defining rule of originator-controlled access control.
- c. A military facility in which only generals can enter a particular room
 - Answer: Mandatory access control because this rule is not set by one person or the general themselves, but rather the system as a whole. Rules like these in the military are set by groups of people and agreed upon as an institution as this requires structure. Since this was not an individual choice it must be mandatory access control.
- d. A university registrar's office, in which a faculty member can see the grades of a particular student provided that the student has given written permission for the faculty member to see them.
 - Answer: Discretionary access control. Only the student can give access to the grades meaning that an individual grants access to the information, which would be discretionary access control.

2. (20 points) Given the security levels TOP SECRET, SECRET, CONFIDENTIAL, and UNCLASSIFIED (ordered from highest to lowest), and the categories A, B, and C, specify what type of access (read, write, both, or neither) is allowed in each of the following situations. Assume that discretionary access controls allow anyone access unless otherwise specified.

Requirements for label A to dominate label B: Label A dominates label B if and only if label A's level is greater than or equal to B's level and A's category set is a superset of B's category set.

- a. Paul, cleared for (TOP SECRET, {A, C}), wants to access a document classified (SECRET, {B, C}).
 - Step 1: We define Paul as the subject and the document as the object. We know that Paul's clearance is $L(\text{Paul}) = (\text{TOP SECRET}, \{A, C\})$ and the document's classification is $L(\text{Document}) = (\text{SECRET}, \{B, C\})$.

- Step 2A: We know that a subject's label must dominate the object's label for read permissions to be granted. So we have to first check that Paul's level is greater than or equal to the document's level. Paul's level is TOP SECRET which is greater than the document's SECRET, so this requirement is satisfied.
 - Step 2B: Next, we must check that Paul's category set is the superset of the document's category set. The document has the categories B and C and so while C is in Paul's category set, B is not. Thus, Paul's category set is not the superset of the document's category set.
 - Step 2C: Since the second requirement for label domination is not satisfied, Paul cannot be granted read permissions.
 - Step 3A: Then, we will check write permissions. We know that a subject may write to an object if the object's label dominates the subject's label. So we have to first check that the document's level is greater than or equal to Paul's level. The document's level is SECRET which is less than TOP SECRET, so this requirement is not satisfied.
 - Step 3B: Next, we must check that the document's category set is the superset of Paul's category set. Paul has the categories A and C and so while C is in the document's category set, A is not. Thus, the document's category set is not the superset of Paul's category set.
 - Step 3C: Since the both requirements for label domination are not satisfied, Paul cannot be granted write permissions.
 - Step 4: In conclusion, Paul has neither read nor write permissions.
- b. Anna, cleared for (CONFIDENTIAL, {C}), wants to access a document classified (CONFIDENTIAL, {B}).
- Step 1: We define Anna as the subject and the document as the object. We know that Anna's clearance is $L(\text{Anna}) = (\text{CONFIDENTIAL}, \{C\})$ and the document's classification is $L(\text{Document}) = (\text{CONFIDENTIAL}, \{B\})$.
 - Step 2A: We know that a subject's label must dominate the object's label for read permissions to be granted. So we have to first check that Anna's level is greater than or equal to the document's level. Anna's level is CONFIDENTIAL which is equal to the document's CONFIDENTIAL, so this requirement is satisfied.
 - Step 2B: Next, we must check that Anna's category set is the superset of the document's category set. The document has category B, which is not part of Anna's category set. Thus, Anna's category set is not the superset of the document's category set.
 - Step 2C: Since the second requirement for read permissions label domination is not satisfied, Anna cannot be granted read permissions.
 - Step 3A: Then, we will check write permissions. We know that a subject may write to an object if the object's label dominates the subject's label. So we have to

first check that the document's level is greater than or equal to Anna's level. The document's level is CONFIDENTIAL which is equal to CONFIDENTIAL, so this requirement is satisfied.

- Step 3B: Next, we must check that the document's category set is the superset of Anna's category set. Anna has category C which is not in the document's category set. Thus, the document's category set is not the superset of Anna's category set.
- Step 3C: Since the second requirement for write permissions label domination is not satisfied, Anna cannot be granted write permissions.
- Step 4: In conclusion, Anna has neither read nor write permissions.

c. Jesse, cleared for (SECRET, {C}), wants to access a document classified (CONFIDENTIAL, {C}).

- Step 1: We define Jesse as the subject and the document as the object. We know that Jesse's clearance is $L(\text{Jesse}) = (\text{SECRET}, \{C\})$ and the document's classification is $L(\text{Document}) = (\text{CONFIDENTIAL}, \{C\})$.
- Step 2A: We know that a subject's label must dominate the object's label for read permissions to be granted. So we have to first check that Jesse's level is greater than or equal to the document's level. Jesse's level is SECRET which is greater than the document's CONFIDENTIAL, so this requirement is satisfied.
- Step 2B: Next, we must check that Jesse's category set is the superset of the document's category set. The document has category C, which is part of Jesse's category set. All the document's categories appear in Jesse's category set so Jesse's is the superset of the document's category set.
- Step 2C: Since the both requirements for read permissions label domination are satisfied, Jesse can be granted read permissions.
- Step 3A: Then, we will check write permissions. We know that a subject may write to an object if the object's label dominates the subject's label. So we have to first check that the document's level is greater than or equal to Jesse's level. The document's level is CONFIDENTIAL which is less than SECRET, so this requirement is not satisfied.
- Step 3B: Next, we must check that the document's category set is the superset of Jesse's category set. Jesse has category C which is in the document's category set. All of Jesse's categories appear in the document's category set so the document set is the superset of Jesse's category set.
- Step 3C: Since the first requirement for write permissions label domination is not satisfied, Jesse cannot be granted write permissions.
- Step 4: In conclusion, Jesse only has read permissions.

d. Sammi, cleared for (TOP SECRET, {A, C}), wants to access a document classified (CONFIDENTIAL, {A}).

- Step 1: We define Sammi as the subject and the document as the object. We know that Sammi's clearance is $L(\text{Sammi}) = (\text{TOP SECRET}, \{A, C\})$ and the document's classification is $L(\text{Document}) = (\text{CONFIDENTIAL}, \{A\})$.
 - Step 2A: We know that a subject's label must dominate the object's label for read permissions to be granted. So we have to first check that Sammi's level is greater than or equal to the document's level. Sammi's level is TOP SECRET which is greater than the document's CONFIDENTIAL, so this requirement is satisfied.
 - Step 2B: Next, we must check that Sammi's category set is the superset of the document's category set. The document has category A, which is part of Sammi's category set. All the document's categories appear in Sammi's category set so Sammi's is the superset of the document's category set.
 - Step 2C: Since the both requirements for read permissions label domination are satisfied, Sammi can be granted read permissions.
 - Step 3A: Then, we will check write permissions. We know that a subject may write to an object if the object's label dominates the subject's label. So we have to first check that the document's level is greater than or equal to Sammi's level. The document's level is CONFIDENTIAL which is less than TOP SECRET, so this requirement is not satisfied.
 - Step 3B: Next, we must check that the document's category set is the superset of Sammi's category set. Sammi has categories A and C, only one of which is in the document's category set. Since all of Sammi's categories do not appear in the document's category set, the document set is not the superset of Sammi's set.
 - Step 3C: Since both requirements for write permissions label domination are not satisfied, Sammi cannot be granted write permissions.
 - Step 4: In conclusion, Sammi only has read permissions.
- e. Robin, who has no clearances (and so works at the UNCLASSIFIED level), wants to access a document classified $(\text{CONFIDENTIAL}, \{B\})$.
- Step 1: We define Robin as the subject and the document as the object. We know that Robin's clearance is $L(\text{Robin}) = (\text{UNCLASSIFIED}, \{\text{NONE}\})$ and the document's classification is $L(\text{Document}) = (\text{CONFIDENTIAL}, \{B\})$.
 - Step 2A: We know that a subject's label must dominate the object's label for read permissions to be granted. So we have to first check that Robin's level is greater than or equal to the document's level. Robin's level is UNCLASSIFIED which is less than the document's CONFIDENTIAL, so this requirement is not satisfied.
 - Step 2B: Next, we must check that Robin's category set is the superset of the document's category set. The document has category B, which is not part of Robin's category set (Robin has no categories). Since none of the document's categories appear in Robin's category set, Robin's is not the superset of the document's category set.

- Step 2C: Since neither requirements for read permissions label domination are satisfied, Robin cannot be granted read permissions.
- Step 3A: Then, we will check write permissions. We know that a subject may write to an object if the object's label dominates the subject's label. So we have to first check that the document's level is greater than or equal to Robin's level. The document's level is CONFIDENTIAL which is greater than UNCLASSIFIED, so this requirement is satisfied.
- Step 3B: Next, we must check that the document's category set is the superset of Robin's category set. Robin has no categories, so all their categories are technically in the document's category set. Since all of Robin's categories appear in the document's category set, the document set is the superset of Robin's set.
- Step 3C: Since both requirements for write permissions label domination are satisfied, Robin can be granted write permissions.
- Step 4: In conclusion, Robin has only write permissions.

3. (20 points) In the Clark-Wilson model, must the TPs be executed serially, or can they be executed in parallel? If the former, why; if the latter, what constraints must be placed on their execution?

Answer: Transaction procedures (TP) are not necessarily limited to a serial timeline. They can be executed in parallel, provided that they meet certain criteria in order to preserve integrity. Firstly, the two programs running should not access and work on the same data at the same time. The primary concern if one of these requirements is violated, then a TP may read and write the same CDI at the same time. This would result in the CDI holding erroneous or inconsistent data. Secondly, whatever action the program is executing needs to finish completely or else the system could be in an inconsistent state, which would break integrity. Thirdly, the system needs to go from a valid state to another valid state. Lastly, any actions occurring at the same time need to still meet authorization rules.

4. (24 points) An affine cipher has the form $c = (am + b) \bmod n$. Suppose m is an integer between 0 and 25, each integer representing a letter.

- a. Let $n = 26$, $a = 3$, and $b = 123$. What is the ciphertext corresponding to the phrase THIS IS A CIPHER MESSAGE.
 - Step 1: We can use the equation for encryption to find each corresponding ciphertext character to the original plaintext character.
 - T: $c = (am + b) \bmod n = (3 * 19 + 123) \bmod 26 = 24 = Y$
 - H: $c = (am + b) \bmod n = (3 * 7 + 123) \bmod 26 = 14 = O$
 - I: $c = (am + b) \bmod n = (3 * 8 + 123) \bmod 26 = 17 = R$
 - S: $c = (am + b) \bmod n = (3 * 18 + 123) \bmod 26 = 21 = V$

- I: $c = (am + b) \bmod n = (3 * 8 + 123) \bmod 26 = 17 = R$
- S: $c = (am + b) \bmod n = (3 * 18 + 123) \bmod 26 = 21 = V$
- A: $c = (am + b) \bmod n = (3 * 0 + 123) \bmod 26 = 19 = T$
- C: $c = (am + b) \bmod n = (3 * 2 + 123) \bmod 26 = 25 = Z$
- I: $c = (am + b) \bmod n = (3 * 8 + 123) \bmod 26 = 17 = R$
- P: $c = (am + b) \bmod n = (3 * 15 + 123) \bmod 26 = 12 = M$
- H: $c = (am + b) \bmod n = (3 * 7 + 123) \bmod 26 = 14 = O$
- E: $c = (am + b) \bmod n = (3 * 4 + 123) \bmod 26 = 5 = F$
- R: $c = (am + b) \bmod n = (3 * 17 + 123) \bmod 26 = 18 = S$
- M: $c = (am + b) \bmod n = (3 * 12 + 123) \bmod 26 = 3 = D$
- E: $c = (am + b) \bmod n = (3 * 4 + 123) \bmod 26 = 5 = F$
- S: $c = (am + b) \bmod n = (3 * 18 + 123) \bmod 26 = 21 = V$
- S: $c = (am + b) \bmod n = (3 * 18 + 123) \bmod 26 = 21 = V$
- A: $c = (am + b) \bmod n = (3 * 0 + 123) \bmod 26 = 19 = T$
- G: $c = (am + b) \bmod n = (3 * 6 + 123) \bmod 26 = 11 = L$
- E: $c = (am + b) \bmod n = (3 * 4 + 123) \bmod 26 = 5 = F$
- Step 2: Then we put all the derived characters together into one string “YORV RV
T ZRMOFS DFVVTLF”.

- b. A requirement for a cipher is that every plaintext letter corresponds to a different ciphertext letter. If a and b are not relatively prime to n , does the affine cipher meet this property? Either prove it does or present a counterexample.

Answer: Yes. We know that the value “ a ” essentially shuffles the possibilities of what the output will be. “ a ” is the main factor because if it is not relatively prime to n , then the ciphertext characters may repeat instead of outputting all possible values. If a and n share a factor, then the adding m “ a ” times will only go through a subset of the numbers before looping back and repeating as opposed to what we want (hitting all n possible values). Say we have $n = 26$ and $a = 2$. The results would only be even numbers (0, 2, 4, ..., 24), so no matter what inputs were used, the outputs would eventually duplicate. If we let $m = 1$ (corresponds to the letter B), then $c = (2(1) + 5) \bmod 26 = 7$ (7 corresponds to the letter H). Then if we let $m = 14$ (corresponds to the letter O), then $c = (2(14) + 5) \bmod 26 = 7$ (corresponds to the letter H). Obviously, B does not equal O but they have the same ciphertext letter H. Additionally, the value “ b ” only shifts the results, so it does not fix the duplication problem. So, we can say that every plaintext letter does not correspond to a different ciphertext letter.

5. (20 points) In the story “‘Repent, Harlequin!’ said the Ticktockman” by Harlan Ellison Download ‘Repent, Harlequin!’ said the Ticktockman” by Harlan Ellison, the Harlequin repeatedly disrupts schedules.

- a. An “insider threat” is usually defined as someone who is trusted with access or information betraying that trust. It may be deliberate, the attacker knowing they are attacking; it may be unintentional, the attacker unaware of the effect of their actions. This story has a classic example of an unintentional insider attack. What is it? What might the consequences be? How does this relate to computer security?

Answer: The classic example is Harlequin. He can be defined as an insider because though he is not an enforcer, he is a part of the system itself and has the power to derail it. His own tardiness causes a domino effect and sets the entire schedule behind. Though he knows he is purposefully tardy, he seems to be unaware of the consequences of his actions. Results can be small, but they tend to snowball in the story into severe issues and emphasize how fragile their society is. This is relevant to computer security because security threats are not always malicious in intent. Someone can make a mistake, which can sometimes lead to major consequences.

- b. Ellison uses an unusual style of writing in this story, in which he begins in the middle, then goes to the beginning, and then to the end. Further, the story has a manic quality due to the choice of words and its structure. How is this similar to handling a computer intrusion incident?

Answer: This is similar to handling an intrusion incident because oftentimes the issue is detected after the attacker is inside and has done damage. In order to figure out how to solve the problem or prevent persistence, you need to first figure out how the attacker entered and initiated the attack, which means working backwards from the “middle”. Then, the end comes when you have successfully repaired any damage done and removed the attacker from the system. It is also similar in the sense that you may have to switch between many different tasks to mitigate the attack/damage, especially if the attacker is still actively messing with the system.